SANDIP UNIVERSITY
UGC Recognised

NAAC GRADE A

PROJECT REPORT

Enterprise Ransomware Assessment: Drafted a Corporate Risk Register Mapped to the NIST CSF Framework

Project domain: Cybersecurity Risk Management **Framework:** NIST Cybersecurity Framework (CSF) 2.0

Abstract

This project presents a lightweight Python tool and a sample corporate ransomware risk register mapped to the six functions of NIST Cybersecurity Framework (CSF) 2.0: Govern, Identify, Protect, Detect, Respond, and Recover. The register records risk scenarios, likelihood and impact ratings, inherent scores, existing controls, recommended treatment actions, owners, target dates, and status. The sample dataset is designed to support workshops and risk discussions; it is not an organization-specific assessment or compliance certification.

1. Introduction

Ransomware can disrupt business operations, expose sensitive information, affect customer trust, and create material recovery costs. Effective preparation requires organizations to identify critical assets and dependencies, evaluate plausible attack scenarios, validate preventive and detective controls, and plan response and recovery. A structured risk register provides a repeatable way to document risks, assign accountability, prioritize treatment, and monitor progress.

2. Objectives

• Create a reusable corporate ransomware risk-register template in CSV format.

• Map representative risks to NIST CSF 2.0 functions and relevant categories.

• Apply a transparent likelihood × impact scoring method with configurable organizational thresholds.

• Record existing controls, proposed treatment, accountable owner, target date, and status.

• Provide an auditable starting point for stakeholder review and ongoing risk governance.

3. Framework Mapping

The NIST CSF 2.0 organizes cybersecurity outcomes into six functions. This sample uses abbreviated function identifiers: GV (Govern), ID (Identify), PR (Protect), DE (Detect), RS (Respond), and RC (Recover). Examples include supplier risk oversight under Govern, asset inventory and risk analysis under Identify, access control and resilience safeguards under Protect, monitoring under Detect, incident management under Respond, and restoration planning under Recover. Category labels in the sample are representative; verify exact subcategory applicability and wording against the official framework.

Function	How it supports ransomware risk management
GV — Govern	Define risk ownership, policies, oversight, and supplier risk expectations.
ID — Identify	Inventory assets and dependencies; assess threats, vulnerabilities, and business impact.
PR — Protect	Apply access controls, awareness, data protection, and infrastructure safeguards.
DE — Detect	Monitor endpoints, identity systems, networks, and suspicious activity.
RS — Respond	Coordinate analysis, containment, communication, and incident management.
RC — Recover	Restore systems and services from clean backups and validated recovery procedures.

4. Methodology and Scoring

The starter register contains ten illustrative risk scenarios covering privileged access, phishing, endpoint detection, network segmentation, backups, incident response readiness, asset inventory, third-party access, vulnerability remediation, and recovery dependencies. Each scenario is scored on a 1–5 likelihood scale and a 1–5 impact scale. Inherent score = likelihood × impact. Example bands are 1–7 Low, 8–14 Moderate, 15–19 High, and 20–25 Critical. These bands should be replaced by the organization's approved criteria if different. Inherent risk is assessed before considering the effect of controls; the script does not calculate residual risk.

5. System Design and Files

Python CLI

The command-line tool creates the sample CSV register or recalculates scores and ratings for a user-edited CSV. It validates that likelihood and impact are integers from 1 through 5.

CSV output

The register is portable and can be reviewed in spreadsheet software, imported into a GRC tool, or used as a workshop input after governance and data handling requirements are considered.

Requirements

The implementation uses the Python standard library only. Python 3.10 or newer is recommended.

6. Running the Tool

`python ransomware_assessment.py` creates `ransomware_risk_register.csv`. To choose another path, run `python ransomware_assessment.py --output my_register.csv`. After editing likelihood and impact values, run `python ransomware_assessment.py --input ransomware_risk_register.csv --output scored_register.csv` to recalculate scores and ratings.

7. Example Risk Register Summary

Risk ID	Risk theme	CSF function	L×I	Rating
R-001	Unmanaged privileged access	PR	20	Critical
R-002	Phishing and credential theft	PR	16	High
R-003	Insufficient endpoint detection	DE	15	High
R-004	Excessive network reachability	PR	15	High
R-005	Backups exposed to ransomware	RC	15	High
R-006	Unverified incident response readiness	RS	12	Moderate
R-007	Critical asset inventory gaps	ID	12	Moderate
R-008	Weak third-party access governance	GV	15	High
R-009	Delayed vulnerability remediation	ID	12	Moderate
R-010	Recovery dependencies not validated	RC	10	Moderate

8. Suggested Assessment Workflow

1. Confirm the scope, business services, critical assets, data, and stakeholders.
2. Workshop threat scenarios and validate business impact and likelihood assumptions.
3. Document control evidence rather than relying only on policy statements.
4. Assign accountable risk owners, treatment owners, deadlines, and completion measures.
5. Assess residual risk after treatments and document acceptance or escalation.
6. Review the register periodically and after significant changes or incidents.

9. Limitations and Governance Considerations

• Sample risks, scores, controls, and mappings are illustrative and must be tailored.

• The project does not scan infrastructure, detect active ransomware, execute malware, or certify compliance.

• A risk register is only one part of a risk management process; it should be supported by evidence, ownership, review cadence, and risk acceptance governance.

• Avoid committing confidential asset names, architecture diagrams, vulnerabilities, or incident details to a public repository.

• Confirm CSF 2.0 mapping and any regulatory or contractual requirements with qualified organizational stakeholders.

10. Conclusion

The project offers a practical starting point for documenting and prioritizing ransomware risks in a corporate setting. By combining a simple scoring method with NIST CSF 2.0 function mapping, it supports structured discussions about accountability, prevention, detection, response, and recovery. Its value depends on organizational validation, evidence-based scoring, ongoing review, and integration with the enterprise risk management process.

Reference

NIST Cybersecurity Framework 2.0 — https://www.nist.gov/cyberframework

Prepared as an educational project report. This document is not a formal audit opinion, certification, or organization-specific risk determination.